ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN

LOGO UIT

Đại học Công nghệ Thông tin

ĐHQG-HCM

BÁO CÁO ĐỒ ÁN LẦN 2

Thời điểm báo cáo: 10/11/2026

LẬP TRÌNH KỊCH BẢN TỰ ĐỘNG HÓA CHO QUẢN TRỊ VÀ BẢO MẬT MẠNG

Mã lớp: NT542.R11

TÊN ĐỀ TÀI

Xây dựng hệ thống tự động đánh giá và khắc phục cấu hình bảo mật tường lửa Palo Alto dựa trên tiêu chuẩn CIS Benchmark

Giảng viên hướng dẫn: ThS. Trần Thị Dung, ThS. Văn Thiên Luân

Sinh viên thực hiện: Huỳnh Minh Hiếu – 23520477

Nguyễn Phát Đạt – 23520258

TP. Hồ Chí Minh, năm 2026

MỤC LỤC

Danh mục bảng ... **iii**

Danh mục hình ảnh ... **iv**

Danh mục mã nguồn ... **v**

CHƯƠNG 1 Giới thiệu về đề tài ... **1**

1.1 Tóm tắt ... **1**

1.2 Nội dung ... **2**

1.2.1 Mục tiêu và Phạm vi dự án ... 2

1.2.2 Phân định phạm vi Manual và Automated trong dự án ... 2

1.2.3 Nhóm khuyến nghị Manual ... 4

1.2.4 Nhóm khuyến nghị Automated ... 5

CHƯƠNG 2 Phương pháp ... **6**

2.1 Phương pháp Đánh giá Thủ công (Manual) ... **6**

2.1.1 Mục đích và Nguyên tắc thực hiện ... 6

2.1.2 Quy trình thao tác đánh giá thủ công ... 6

2.1.3 Hai phương thức thao tác: Giao diện đồ họa (GUI) và Dòng lệnh (CLI) 7

2.1.4 Ví dụ chi tiết 1: CIS 1.2.1 – Permitted IP Addresses ... 9

2.1.5 Ví dụ chi tiết 2: CIS 1.3.2 – Quy định độ dài mật khẩu tối thiểu ... 10

2.2 Phương pháp Đánh giá Tự động (Automated) ... **11**

2.2.1 Mục đích và Lựa chọn công nghệ ... 11

2.2.2 Mô hình xử lý và Kiến trúc dữ liệu tại Linux Bastion ... 11

2.2.3 Thiết kế Quy tắc và Trạng thái Kết quả ... 13

2.2.4 Mã nguồn minh họa kiểm tra tự động ... 14

2.3 Phương pháp Tự động hóa Điều phối Từ xa với Ansible (Remote Automated) ... **15**

2.3.1 Mô hình Điều phối Cụm thiết bị (Fleet Management) ... 15

2.3.2 Hệ thống Kịch bản Ansible Playbooks ... 16

CHƯƠNG 3 Triển khai ... **16**

3.1 Mô hình triển khai ... **16**

3.2 Triển khai Đánh giá Thủ công (Manual) ... **20**

3.3 Triển khai Đánh giá Tự động hóa (Automated) ... **22**

3.3.1 Cấu trúc mã nguồn hệ thống ... 22

3.3.2 Kết quả thực nghiệm quét tự động trên cụm Firewall ... 22

3.3.3 Điều phối quét tự động toàn bộ Fleet qua Ansible ... 24

Tài liệu tham khảo **25**

DANH MỤC BẢNG

1 Các nhóm nội dung CIS Benchmark được nhóm lựa chọn triển khai 3
2 Tổng hợp phương thức kiểm tra thủ công qua GUI và CLI 7
3 Đối chiếu kết quả đánh giá thực tế cho CIS 1.2.1 10
4 Bảng phân bổ địa chỉ IP và vai trò các thiết bị trong lab CMC Cloud 19
5 Bảng tổng hợp kết quả đánh giá thủ công trên cụm tường lửa Palo Alto 20

DANH MỤC HÌNH ẢNH

1 Kiểm tra thực tế Permitted IP Addresses trên PA-CIS-01 qua Web GUI 10
2 Giao diện kiểm tra độ dài mật khẩu tối thiểu trên tường lửa Palo Alto 10
3 Kiến trúc quy trình đánh giá tự động hóa cấu hình Palo Alto Firewall 13
4 Sơ đồ topo kiến trúc mạng lab CMC Cloud triển khai thực nghiệm trong VPC-LTKB 18
5 Kết quả thực thi tự động hóa quét tuân thủ CIS Benchmark trên thiết bị tường lửa 24

DANH MỤC MÃ NGUỒN

1 Truy vấn Permitted IP Addresses qua CLI 9
2 Cấu trúc khai báo quy tắc CIS trong tệp tin cis_controls.yaml 13
3 Mã nguồn Python tự động kiểm tra tiêu chí CIS 1.4.1 14
4 Cấu hình Ansible Inventory quản lý cụm tường lửa Palo Alto 15
5 Nhật ký thực thi quét tự động 30/30 CIS Controls trên Linux Bastion 22
6 Thực thi điều phối quét tự động toàn bộ Fleet qua Ansible 24

1 Giới thiệu về đề tài

1.1 Tóm tắt

Trong cấu trúc hạ tầng an ninh mạng doanh nghiệp hiện đại, tường lửa thế hệ mới (Next-Generation Firewall – NGFW) giữ vai trò then chốt tại ranh giới phân tách các vùng mạng, thực thi chính sách kiểm soát lưu lượng và phát hiện các mối đe dọa chuyên sâu. Tuy nhiên, hiệu năng phòng thủ của tường lửa không chỉ phụ thuộc vào chủng loại phần cứng hoặc bản quyền tính năng mà phụ thuộc trực tiếp vào mức độ chuẩn mực và an toàn của cấu hình hệ thống. Thực tế vận hành cho thấy nhiều sự cố rò rỉ dữ liệu và xâm nhập xuất phát từ các sai sót cấu hình cơ bản, ví dụ như mở quyền truy cập quản trị quá rộng ra Internet, duy trì các giao thức quản trị không mã hóa như HTTP hoặc Telnet, thiết lập chính sách mật khẩu yếu, không bật cơ chế giới hạn phiên đăng nhập rảnh rỗi hoặc bỏ quên các cấu hình đồng bộ bảo vệ dự phòng.

Nhằm chuẩn hóa việc đánh giá và củng cố bảo mật cấu hình, Center for Internet Security (CIS) đã ban hành tài liệu chuẩn đối chuẩn mang tên CIS Palo Alto Firewall 11 Benchmark phiên bản v1.2.0 (công bố năm 2025). Tài liệu cung cấp hệ thống khuyến nghị bảo mật chuyên sâu cho hệ điều hành PAN-OS phiên bản 11.x, phân chia theo các cấp độ bảo vệ (Profile Level 1 và Level 2), đồng thời quy định rõ cơ sở lý luận an ninh, các bước kiểm tra (Audit) và quy trình khắc phục (Remediation).

Đề tài hướng đến giải quyết trọn vẹn bài toán nâng cao mức độ an toàn cấu hình tường lửa thông qua việc xây dựng một hệ sinh thái kết hợp song song hai phương pháp:

- **Phương pháp Đánh giá Thủ công (Manual):** Quản trị viên tiến hành đối chiếu trực tiếp cấu hình trên giao diện Web GUI hoặc giao diện dòng lệnh CLI (Console/SSH) với tiêu chuẩn CIS Benchmark, từ đó hiểu sâu bản chất kỹ thuật và xây dựng tập dữ liệu đối chứng chuẩn xác.
- **Phương pháp Đánh giá và Khắc phục Tự động (Automated):** Xây dựng công cụ lập trình bằng ngôn ngữ Python tương tác trực tiếp với tường lửa Palo Alto qua giao diện lập trình ứng dụng PAN-OS XML API trên nền HTTPS bảo mật cổng 443, kết hợp nền tảng điều phối Ansible để thực hiện quét tuân thủ đồng thời trên toàn bộ cụm thiết bị (Fleet Management) và áp dụng các biện pháp làm cứng cấu hình một cách nhanh chóng, chuẩn xác.

Môi trường thử nghiệm thực tế của đề tài được triển khai hoàn chỉnh trên hạ tầng đám mây CMC Cloud bên trong mạng riêng ảo **VPC-LTKB** với dải mạng tổng thể **10.0.0.0/16**. Hệ thống bao gồm cụm hai tường lửa Palo Alto VM-Series (phiên bản PAN-OS 11.2.5) thiết lập cơ chế High Availability Active/Passive với hai địa chỉ IP ảo dự phòng (Pair Address) gồm **VIP Untrust: 10.0.1.100** và **VIP Trust: 10.0.20.100**, phối hợp cùng máy chủ điều khiển **VM-LINUX-BASTION** (`10.0.10.20`), máy trạm đồ họa **VM-WINDOW-BASTION** (`10.0.10.21`) và máy client nội bộ **VM-CLIENT-TEST**

(`10.0.20.20`) phục vụ kiểm thử lưu lượng an ninh qua firewall.

Kho mã nguồn của đề tài: `github.com/mhieudzvcl/CIS-Benchmark-PaloAlto`.

1.2 Nội dung

1.2.1 Mục tiêu và Phạm vi dự án

Trước đây khi chưa có công cụ hỗ trợ, người quản trị thường phải mở từng trang giao diện web của firewall, nhìn từng thông số rồi ghi chép lại vào file Excel. Cách làm này rất tốn thời gian, dễ nhìn nhầm khi phải rà soát quá nhiều mục và gần như không thể thực hiện định kỳ thường xuyên khi số lượng firewall tăng lên. Từ thực tế đó, nhóm đặt ra mục tiêu cho đồ án: *Làm sao để xây dựng một quy trình kiểm tra vừa nhanh, vừa chính xác, có đầy đủ bằng chứng đối chứng và có thể tự động đánh giá cũng như khắc phục cấu hình theo chuẩn CIS Benchmark trên các tường lửa Palo Alto?*

Để trả lời câu hỏi trên, nhóm đề ra 5 mục tiêu cụ thể:

1. Tìm hiểu kỹ tài liệu CIS Palo Alto Firewall 11 Benchmark v1.2.0, nắm rõ cách thức kiểm tra và các bước khắc phục cho từng khuyến nghị.
2. Chọn ra một tập gồm 30 CIS Controls tiêu biểu, bám sát các tính năng quan trọng và hay dùng nhất trên hệ điều hành PAN-OS 11.2.5.
3. Xây dựng quy trình kiểm tra thủ công qua cả giao diện Web GUI và dòng lệnh CLI, có bảng ghi nhận kết quả và hình ảnh chụp màn hình thực tế làm căn cứ đối chứng.
4. Lập trình công cụ bằng Python kết nối qua PAN-OS XML API, đọc dữ liệu cấu hình đang chạy (Running Config) cùng trạng thái vận hành thời gian thực (Operational Status) để tự động đánh giá kết quả.
5. Ứng dụng Ansible để quản lý và điều phối từ xa, cho phép quét kiểm tra và tự động cấu hình bảo mật đồng thời trên toàn bộ các firewall trong hệ thống mà không cần cài thêm phần mềm lên thiết bị.

1.2.2 Phân định phạm vi Manual và Automated trong dự án

Để tránh nhầm lẫn trong quá trình đọc báo cáo, nhóm làm rõ sự khác biệt giữa hai góc nhìn:

- **Theo phân loại gốc của CIS Benchmark:** CIS xếp một mục là *Manual* khi việc kết luận an toàn bắt buộc phải có người quản trị xem xét theo ngữ cảnh thực tế của mạng. Ví dụ như mục CIS 1.2.1 về danh sách IP quản trị, máy móc chỉ biết là có khai báo IP hay không, còn việc các IP đó có đúng là máy của người quản trị được cấp phép hay không thì phải do con người kiểm tra lại. Ngược lại, CIS xếp là *Automated* cho những mục có ngưỡng số rõ ràng hoặc điều kiện bật

tắt cụ thể mà máy tính có thể tự so sánh được, ví dụ như mục CIS 1.3.2 yêu cầu mật khẩu phải dài từ 12 ký tự trở lên.

- **Theo cách triển khai của nhóm trong đồ án:** Nhóm áp dụng cả hai phương pháp cho toàn bộ 30 CIS Controls đã chọn:

    1. *Kiểm tra thủ công (Manual 30/30 mục):* Nhóm tự đăng nhập vào Web GUI hoặc CLI của từng firewall, tìm đến đúng trang cấu hình, ghi nhận giá trị và chụp ảnh lại để làm bộ dữ liệu chuẩn đối chứng.
    2. *Kiểm tra tự động (Automated 30/30 mục):* Nhóm viết code Python trong `src/cis_scanner.py` và các kịch bản Ansible trong thư mục `ansible/playbooks/` để tự động kiểm tra cả 30 mục. Đối với những mục mà CIS đánh dấu là Manual, chương trình của nhóm vẫn tự động trích xuất dữ liệu ra, đem đối chiếu với danh sách cho phép (whitelist) đã cấu hình trước và đưa ra cảnh báo để người quản trị đưa ra quyết định nhanh hơn rất nhiều.

Bảng 1 tóm tắt 6 nhóm nội dung với 30 khuyến nghị CIS được nhóm lựa chọn triển khai trong đồ án.

Bảng 1: Các nhóm nội dung CIS Benchmark được nhóm lựa chọn triển khai

STT	Nhóm nội dung	Số lượng	Hạng mục và Ý nghĩa kỹ thuật triển khai
1	Quản trị thiết bị (Device Setup & Mgmt)	9 controls	Cấu hình banner cảnh báo đăng nhập, bật log cảnh báo khi tải Data Plane cao, giới hạn IP được phép quản trị, tắt HTTP và Telnet, đặt thời gian tự ngắt phiên rảnh rỗi và khóa tài khoản khi gõ sai mật khẩu nhiều lần.
2	Chính sách mật khẩu (Password Profiles)	10 controls	Bật yêu cầu độ phức tạp mật khẩu, quy định độ dài tối thiểu, số lượng chữ hoa, chữ thường, chữ số, ký tự đặc biệt, thời hạn đổi mật khẩu, lưu lịch sử mật khẩu cũ và không để tồn tại các profile ghi đè chính sách chung.
3	Dịch vụ hệ thống và Ghi log (Services & Logging)	3 controls	Bật xác thực máy chủ cập nhật chính hãng, cấu hình máy chủ NTP đồng bộ thời gian chính và phụ, cấu hình chuyển tiếp log tập trung về Syslog Server.

Còn tiếp ở trang sau

Bảng 1 (tiếp theo)

STT	Nhóm nội dung	Số lượng	Hạng mục và Ý nghĩa kỹ thuật triển khai
4	Độ sẵn sàng cao (High Availability – HA)	3 controls	Kiểm tra trạng thái đồng bộ giữa hai firewall Active và Passive, bật cơ chế giám sát đường truyền (Path Monitoring), để cổng Passive ở chế độ Auto và tắt tính năng giành quyền (Preemption).
5	Lọc bảo vệ vùng mạng (Zone Protection)	2 controls	Cấu hình Zone Protection Profile để chống tấn công SYN Flood bằng kỹ thuật SYN Cookies, tự động loại bỏ các gói tin giả mạo IP Spoofing và các gói tin TCP bất thường.
6	Chính sách bảo mật (Security Policies)	3 controls	Kiểm tra không cho phép mở cổng ANY từ vùng Untrust, đặt luật chặn các IP độc hại lên đầu danh sách chính sách và bật ghi log ở cuối phiên cho các luật mặc định.

1.2.3 Nhóm khuyến nghị Manual

Theo tài liệu chuẩn của CIS, nhóm khuyến nghị Manual là những tiêu chí mà việc khẳng định trạng thái an toàn cần sự can thiệp của con người nhằm đối chiếu với chính sách an ninh nội bộ hoặc kiến trúc mạng thực tế. Một trường cấu hình tồn tại trong hệ thống chưa đủ để khẳng định là đạt, mà giá trị của trường đó phải tương thích hoàn toàn với bối cảnh vận hành.

Trong số các tiêu chí thuộc nhóm này, nhóm lựa chọn hai ví dụ điển hình để minh họa chi tiết bản chất đánh giá:

- **Ví dụ 1: CIS 1.2.1 – Đảm bảo cấu hình Permitted IP Addresses cho cổng Management:** Tiêu chuẩn yêu cầu cổng quản trị của firewall chỉ được phép tiếp nhận kết nối từ các địa chỉ IP hoặc dải mạng quản trị được chỉ định rõ ràng. Trong môi trường lab CMC Cloud của nhóm, hai máy trạm quản trị được cấp phát IP tĩnh là Linux Bastion (`10.0.10.20/32`) và Windows Bastion (`10.0.10.21/32`). Nếu người quản trị chỉ cấu hình một danh sách IP bất kỳ hoặc cấu hình dải mở rộng `0.0.0.0/0`, máy móc khi chỉ kiểm tra sự tồn tại của danh sách có thể đánh giá nhầm là có cấu hình, nhưng con người khi xem xét sẽ phát hiện đây là sai phạm nghiêm trọng mở toang cổng quản trị cho kẻ tấn công dò quét.
- **Ví dụ 2: CIS 7.3 – Đảm bảo quy tắc chặn IP độc hại nằm ở đầu bảng chính sách an ninh:** Tiêu chuẩn khuyến nghị các luật Drop hoặc Deny lưu lượng

từ các địa chỉ IP hoặc dải mạng có rủi ro cao (như danh sách External Dynamic List hoặc dải IP tấn công đã nhận diện) phải được đặt tại các vị trí ưu tiên cao nhất (Top of Rulebase). Việc đánh giá yêu cầu người quản trị đọc thứ tự thực thi của danh sách luật trên firewall để bảo đảm lưu lượng độc hại bị triệt tiêu ngay trước khi được xử lý bởi các luật cho phép phía sau.

1.2.4 Nhóm khuyến nghị Automated

Ngược lại với nhóm Manual, các khuyến nghị thuộc nhóm Automated sở hữu các điều kiện đo lường kỹ thuật tường minh, có thể biểu diễn chính xác bằng các mệnh đề toán học, logic nhị phân hoặc so sánh ngưỡng số nguyên.

Nhóm lựa chọn bốn ví dụ tiêu biểu thuộc các phân nhóm khác nhau để làm rõ cơ chế kiểm tra tự động:

- **Ví dụ 1: CIS 1.3.2 – Quy định độ dài mật khẩu quản trị tối thiểu từ 12 ký tự trở lên:** Tiêu chí này được mô hình hóa bằng biểu thức toán học:

$$\text{Status}(1.3.2) = \begin{cases} \text{PASS}, & \text{khi } L_{\min} \geq 12 \text{ và Complexity} = \text{Enabled} \\ \text{FAIL}, & \text{khi } L_{\min} < 12 \text{ hoặc Complexity} = \text{Disabled} \\ \text{REVIEW}, & \text{khi không trích xuất được trường cấu hình} \end{cases}$$

  trong đó $L_{\min}$ là giá trị trường `minimum-length` đọc từ cấu hình.

- **Ví dụ 2: CIS 1.4.1 – Thiết lập thời gian ngắt phiên rảnh rỗi không vượt quá 10 phút:** Biểu thức logic so sánh ngưỡng số:

$$\text{Status}(1.4.1) = \begin{cases} \text{PASS}, & \text{khi } 1 \leq T_{\text{idle}} \leq 10 \\ \text{FAIL}, & \text{khi } T_{\text{idle}} > 10 \text{ hoặc } T_{\text{idle}} = 0 \\ \text{REVIEW}, & \text{khi thiếu thẻ cấu hình} \end{cases}$$

  với T_{idle} là giá trị trường `idle-timeout`. Giá trị 0 nghĩa là không bao giờ hết hạn phiên, tiềm ẩn rủi ro chiếm đoạt phiên quản trị rảnh rỗi.

- **Ví dụ 3: CIS 1.2.3 – Vô hiệu hóa hoàn toàn dịch vụ HTTP và Telnet trên cổng Management:** Điều kiện logic nhị phân khẳng định cả hai dịch vụ không mã hóa đều phải ở trạng thái tắt:

$$\text{Status}(1.2.3) = (\text{HTTP} = \text{Disabled}) \wedge (\text{Telnet} = \text{Disabled})$$

- **Ví dụ 4: CIS 6.15 – Kích hoạt bảo vệ SYN Flood bằng SYN Cookies trong Zone Protection Profile:** Chương trình tự động kiểm tra đối tượng Zone Protection áp dụng trên các vùng mạng untrust, xác nhận tùy chọn kích hoạt `syn-cookies` có giá trị kích hoạt và ngưỡng kích hoạt (threshold) được thiết lập hợp lệ.

2 Phương pháp

2.1 Phương pháp Đánh giá Thủ công (Manual)

2.1.1 Mục đích và Nguyên tắc thực hiện

Đánh giá thủ công là phương pháp mà người quản trị trực tiếp truy cập vào thiết bị tường lửa Palo Alto để quan sát, đối chiếu các thông số cấu hình và trạng thái thực thi với các tiêu chí trong CIS Benchmark. Phương pháp này đóng vai trò thiết yếu trong giai đoạn đầu của dự án nhằm giúp nhóm nắm vững kiến trúc PAN-OS, xác định chính xác các đường dẫn trên giao diện đồ họa và dòng lệnh, đồng thời tạo ra một tập kết quả chuẩn để kiểm chứng tính đúng đắn của chương trình tự động hóa.

Khi tiến hành đánh giá thủ công, nhóm tuân thủ nghiêm ngặt nguyên tắc năm yếu tố thông tin bắt buộc:

1. **Mã khuyến nghị (Control ID):** Xác định rõ mã điều khoản trong tài liệu CIS Benchmark v1.2.0.
2. **Tiêu chí kỹ thuật mong đợi:** Ngưỡng hoặc giá trị an toàn mà tài liệu quy định.
3. **Giá trị quan sát thực tế:** Thông số thực sự đang được lưu và áp dụng trên firewall.
4. **Đánh giá tuân thủ:** Phân loại kết quả rõ ràng thành `PASS`, `FAIL`, `REVIEW` hoặc `N/A`.
5. **Minh chứng thực nghiệm:** Hình ảnh chụp màn hình thể hiện rõ tên thiết bị, đường dẫn cấu hình và nhãn thời gian thực hiện.

2.1.2 Quy trình thao tác đánh giá thủ công

Do danh mục các khuyến nghị đã được xác định cụ thể từ Chương 1, quy trình thực hiện đánh giá thủ công trong thực tế được tiến hành theo các bước kỹ thuật tuần tự sau:

1. **Thiết lập phiên kết nối an toàn:** Từ máy trạm Windows Bastion (`10.0.10.21`), người quản trị mở trình duyệt web truy cập địa chỉ IP quản trị của thiết bị qua giao thức HTTPS (ví dụ: `https://10.0.10.11` cho PA-CIS-01) hoặc mở phiên SSH bảo mật đến cổng quản trị.
2. **Định vị đối tượng cấu hình:** Căn cứ vào mô tả kỹ thuật của khuyến nghị, người quản trị điều hướng chính xác đến phân mục cấu hình trên Web GUI hoặc gõ lệnh truy vấn tương ứng trong CLI.
3. **Trích xuất và Ghi nhận giá trị:** Đọc giá trị cấu hình đang lưu trong Running Configuration hoặc truy vấn trạng thái hoạt động tức thời của hệ thống.

4. **Đối chiếu và Đưa ra kết luận:** So sánh giá trị thực tế với ngưỡng chuẩn của CIS Benchmark. Nếu hoàn toàn thỏa mãn, ghi nhận `PASS`. Nếu vi phạm, ghi nhận `FAIL`. Nếu giá trị phụ thuộc vào ngữ cảnh chưa rõ ràng, ghi nhận `REVIEW`.
5. **Lưu vết bằng chứng:** Chụp ảnh màn hình giao diện hiển thị rõ thông số và lưu trữ vào kho tư liệu kiểm tra của đề tài.

2.1.3 Hai phương thức thao tác: Giao diện đồ họa (GUI) và Dòng lệnh (CLI)

Trong quá trình quản trị hệ điều hành PAN-OS, quản trị viên có thể tiếp cận cấu hình thông qua hai giao diện chính:

- **Giao diện Đồ họa Web (GUI):** Trực quan, dễ sử dụng, thể hiện rõ các trường thông tin trong các bảng biểu và hộp thoại. Phù hợp cho việc kiểm tra tổng quan các chính sách bảo mật, chứng chỉ số và cấu hình hồ sơ bảo vệ.
- **Giao diện Dòng lệnh (CLI):** Truy cập thông qua SSH hoặc cổng Console. CLI cho phép truy vấn nhanh các dòng cấu hình dạng câu lệnh gán (`set`) hoặc định dạng XML cấu trúc (`show config running`), đồng thời cung cấp các lệnh vận hành chuyên sâu (`show high-availability state`, `show system info`) mà giao diện GUI không hiển thị đầy đủ.

Bảng 2 tổng hợp phương thức thao tác cho toàn bộ các nhóm khuyến nghị tiêu biểu trong đề tài, thể hiện rõ những tiêu chí có thể kiểm tra qua GUI, qua CLI hoặc có thể áp dụng linh hoạt cả hai cách.

Bảng 2: Tổng hợp phương thức kiểm tra thủ công qua GUI và CLI

Mã CIS	Tên khuyến nghị	Phương thức	Thao tác thực hiện trên hệ thống
1.1.2	Legal Notice Login Banner	Cả hai	GUI: **Device** → **Setup** → **Management** → Banners. CLI: `show config running | match login-banner`
1.1.3	Log on High DP Load	Cả hai	GUI: **Device** → **Setup** → **Management** → Logging. CLI: `show config running | match enable-log-high-dp-load`
1.2.1	Permitted IP Management	Cả hai	GUI: **Device** → **Setup** → **Interfaces** → Management. CLI: `show config running | match permitted-ip`

Còn tiếp ở trang sau

Bảng 2 (tiếp theo)

Mã CIS	Tên khuyến nghị	Phương thức	Thao tác thực hiện trên hệ thống
1.2.3	Disable HTTP/Telnet Mgmt	Cả hai	GUI: Bỏ chọn ô HTTP và Telnet tại Management Interface. CLI: `show config running | match "http|telnet"`
1.3.1	Password Complexity	Cả hai	GUI: **Device** → **Setup** → **Management** → Password. CLI: `show config running | match password-complexity`
1.3.2	Password Min Length ≥ 12	Cả hai	GUI: Đọc giá trị Minimum Length tại Password Complexity. CLI: `show config running | match minimum-length`
1.4.1	Idle Timeout ≤ 10 phút	Cả hai	GUI: **Device** → **Setup** → **Management** → Authentication. CLI: `show config running | match idle-timeout`
1.4.2	Failed Attempts Lockout ≤ 5	Cả hai	GUI: Đọc giá trị Failed Attempts tại Authentication Settings. CLI: `show config running | match failed-attempts`
1.6.2	NTP Primary and Secondary	Cả hai	GUI: **Device** → **Setup** → **Services** → NTP. CLI: `show config running | match ntp-servers`
3.1	HA Peer Synchronization	Cả hai	GUI: **Dashboard** → High Availability Widget. CLI: `show high-availability state` (Operational)
3.3	HA Passive Link Auto	Cả hai	GUI: **Device** → **High Availability** → General. CLI: `show config running | match passive-link-state`

Còn tiếp ở trang sau

Bảng 2 (tiếp theo)

Mã CIS	Tên khuyến nghị	Phương thức	Thao tác thực hiện trên hệ thống
6.15	SYN Flood Protection	Web GUI	GUI: **Network** → **Zone Protection** → SYN Cookies. CLI: Cần duyệt cây cấu hình XML phức tạp
7.3	Block Malicious IP Top Rule	Web GUI	GUI: **Policies** → **Security**, kiểm tra thứ tự rule. CLI: `show config running | match "rulebase security"`

2.1.4 Ví dụ chi tiết 1: CIS 1.2.1 – Permitted IP Addresses

Mục tiêu bảo mật: Ngăn chặn hoàn toàn các truy cập trái phép đến cổng quản trị của firewall bằng cách chỉ cho phép các IP thuộc vùng quản trị tin cậy.

Thao tác thực hiện qua GUI:

1. Từ máy trạm Windows Bastion, đăng nhập vào giao diện web của PA-CIS-01 (`https://10.0.10.11`).
2. Điều hướng theo menu: **Device** → **Setup** → **Interfaces** → nhấn vào liên kết **Management**.
3. Tại hộp thoại cấu hình cổng Management, tìm đến khung *Permitted IP Addresses*.
4. Đọc danh sách địa chỉ IP được khai báo và đối chiếu với thiết kế mạng. Trong lab CMC Cloud, danh sách hợp lệ bắt buộc chỉ gồm `10.0.10.20/32` (Linux Bastion) và `10.0.10.21/32` (Windows Bastion).

Thao tác thực hiện qua CLI: Mở phiên SSH từ Linux Bastion đến firewall:

Mã nguồn 1: Truy vấn Permitted IP Addresses qua CLI

```
admin@PA-CIS-01> set cli pager off
admin@PA-CIS-01> configure
admin@PA-CIS-01# show deviceconfig system permitted-ip
permitted-ip {
    10.0.10.20/32;
    10.0.10.21/32;
}
[edit]
```

Bảng 3: Đối chiếu kết quả đánh giá thực tế cho CIS 1.2.1

Thuộc tính đánh giá	Trường hợp an toàn (Đạt)	Trường hợp mất an toàn (Không đạt)
Danh sách địa chỉ khai báo	`10.0.10.20/32`, `10.0.10.21/32`	Trống (bỏ trống) hoặc chứa `0.0.0.0/0`
Đối chiếu thiết kế mạng	Đúng hai máy trạm Bastion quản trị	Cho phép dải mạng lạ hoặc mở toàn Internet
Đánh giá tuân thủ	**PASS**	**FAIL**

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_2_1.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 1: Kiểm tra thực tế Permitted IP Addresses trên PA-CIS-01 qua Web GUI

2.1.5 Ví dụ chi tiết 2: CIS 1.3.2 – Quy định độ dài mật khẩu tối thiểu

Mục tiêu bảo mật: Đảm bảo mật khẩu của các tài khoản quản trị cục bộ có độ dài tối thiểu 12 ký tự nhằm vô hiệu hóa các cuộc tấn công vét cạn (brute-force) hoặc tấn công từ điển.

Thao tác thực hiện:

1. Đăng nhập GUI của tường lửa PA-CIS-01.
2. Điều hướng đến: **Device** → **Setup** → **Management** → nhấn vào biểu tượng cấu hình tại khung **Minimum Password Complexity**.
3. Kiểm tra ô chọn *Enable Password Complexity* có được đánh dấu hay không, sau đó đọc thông số tại ô *Minimum Length*.
4. So sánh giá trị với ngưỡng quy định của CIS (≥ 12).

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_3_2.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 2: Giao diện kiểm tra độ dài mật khẩu tối thiểu trên tường lửa Palo Alto

2.2 Phương pháp Đánh giá Tự động (Automated)

2.2.1 Mục đích và Lựa chọn công nghệ

Phương pháp đánh giá tự động hóa nhằm chuyển đổi toàn bộ các bước kiểm tra thủ công lặp đi lặp lại thành các quy trình thực thi chính xác bằng phần mềm. Mục tiêu là rút ngắn thời gian đánh giá từ hàng chục phút xuống chỉ còn vài giây, loại bỏ hoàn toàn các sai sót chủ quan của con người và cho phép thực thi định kỳ tự động trong mô hình DevSecOps.

Hệ thống được phát triển dựa trên nền tảng ngôn ngữ Python 3 kết hợp các thư viện chuyên dụng:

- **`requests`**: Xử lý các kết nối HTTPS, quản lý phiên làm việc, gửi tham số truy vấn và xác thực chứng chỉ số TLS.
- **`lxml`**: Thư viện phân tích cú pháp XML hiệu năng cao, hỗ trợ truy vấn các node cấu hình thông qua biểu thức XPath tiêu chuẩn.
- **`PyYAML`**: Đọc và nạp các tập luật kiểm tra được định nghĩa dưới dạng tệp tin cấu hình YAML dễ mở rộng.
- **`Jinja2`**: Sinh báo cáo kết quả đánh giá dưới định dạng HTML trực quan, sinh động.
- **`Rich`**: Hiển thị tiến trình quét, bảng tổng kết trạng thái và nhật ký thực thi đẹp mắt trên giao diện Terminal.

2.2.2 Mô hình xử lý và Kiến trúc dữ liệu tại Linux Bastion

Làm rõ kiến trúc kết nối tại Linux Bastion: Nhóm khẳng định rõ: *Trên máy chủ Linux Bastion, chương trình đánh giá tự động tuyệt đối KHÔNG sử dụng SSH để can thiệp cấu hình hoặc phân tích luồng văn bản (CLI scraping).* Việc không sử dụng SSH xuất phát từ các lý do kỹ thuật an ninh mạng sau:

1. Luồng dữ liệu trả về qua SSH là văn bản không có cấu trúc (unstructured text stream), chứa các mã điều khiển định dạng terminal và phụ thuộc vào phiên bản hiển thị của thiết bị, khiến bộ phân tích dễ bị đổ vỡ khi thay đổi firmware PAN-OS.
2. Chi phí mở phiên SSH và thời gian chờ tải dữ liệu dòng lệnh rất lớn, không phù hợp cho việc đánh giá nhanh trên quy mô nhiều thiết bị.
3. Tương tác trực tiếp qua SSH tiềm ẩn rủi ro lộ shell quản trị và không có cơ chế quản lý giao dịch (transaction) nguyên khối an toàn.

Thay vào đó, hệ thống chuẩn hóa việc tương tác thông qua **PAN-OS XML API trên nền giao thức HTTPS bảo mật cổng 443**. Hệ thống sử dụng cơ chế xác thực API Key có thời hạn và kiểm tra toàn vẹn mã hóa TLS.

Hai phương thức thu thập dữ liệu chuyên sâu: Để đánh giá toàn diện một thiết bị tường lửa, hệ thống triển khai hai phương thức thu thập dữ liệu riêng biệt:

1. **Thu thập Cấu hình Đang hoạt động (Running Configuration):** Gửi request dạng HTTP GET hoặc POST với tham số:

   ```
   https://<FIREWALL-IP>/api/?type=config&action=show&xpath=/config
   ```

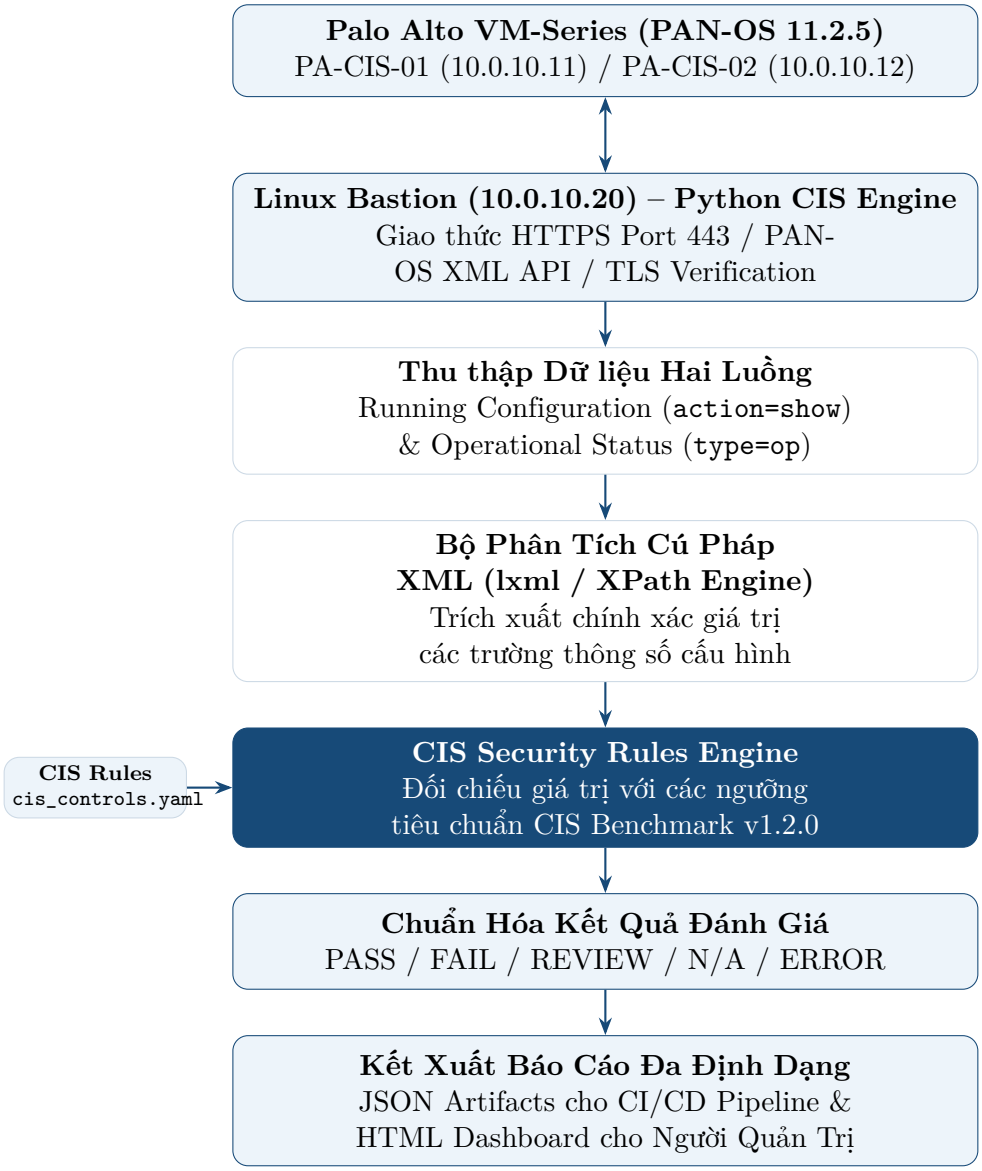
   Yêu cầu này trích xuất toàn bộ cây dữ liệu cấu hình XML đang có hiệu lực hoạt động trên hệ thống (đã được Commit thành công). Cây cấu hình này là nguồn dữ liệu chuẩn xác cho 27/30 tiêu chí tĩnh, bao gồm thông số mật khẩu, dịch vụ mạng, banner cảnh báo và các profile bảo mật. Cần phân biệt rõ Running Configuration với Candidate Configuration (cấu hình nháp chưa Commit thu thập bằng `action=get`).

2. **Thu thập Trạng thái Vận hành Thời gian thực (Operational Status):** Nhiều tiêu chí an ninh quan trọng không thể xác định chỉ dựa vào file cấu hình tĩnh. Điển hình như cơ chế High Availability: file cấu hình chỉ cho biết hai thiết bị được gán địa chỉ IP kết nối với nhau, nhưng không thể khẳng định hai máy đã bắt tay đồng bộ thành công hay đường truyền giám sát có bị đứt gãy hay không. Đối với các tiêu chí này, hệ thống gửi các lệnh vận hành XML Op Commands:

   ```
   https://<FIREWALL-IP>/api/?type=op&cmd=<show><high-availability><state></state>
   ```

   Tường lửa sẽ phản hồi cây XML thể hiện trạng thái hoạt động thực tế tại thời điểm quét: trạng thái node (Active, Passive, Suspended), trạng thái đồng bộ cấu hình (Synchronized) và trạng thái kết nối cổng HA1, HA2.

Hình 3 minh họa kiến trúc quy trình xử lý tự động hóa từ khâu kết nối đến khi kết xuất báo cáo.



Hình 3: Kiến trúc quy trình đánh giá tự động hóa cấu hình Palo Alto Firewall

2.2.3 Thiết kế Quy tắc và Trạng thái Kết quả

Các quy tắc kiểm tra được định nghĩa trong tệp tin `rules/cis_controls.yaml`. Cấu trúc quy tắc bao gồm mã định danh, tiêu đề, loại kiểm tra và các ngưỡng so sánh tương ứng. Mã nguồn 2 minh họa cấu trúc khai báo một số quy tắc điển hình.

Mã nguồn 2: Cấu trúc khai báo quy tắc CIS trong tệp tin cis_controls.yaml

```
benchmark: 'CIS Palo Alto Firewall 11 Benchmark v1.2.0'
controls:
  - id: '1.3.2'
    title: 'Minimum password length >= 12'
    type: password_number
    field: minimum-length
    comparator: gte
    threshold: 12

```

```
  - id: '1.4.1'
    title: 'Management idle timeout <= 10 minutes'
    type: idle_timeout

  - id: '3.1'
    title: 'HA peer state / synchronization'
    type: ha_sync

  - id: '6.15'
    title: 'Zone Protection Profile enables SYN Flood protection'
    type: zone_protection_syn_cookies
```

Hệ thống quy ước 5 trạng thái kết quả thống nhất:

- **PASS:** Dữ liệu thu thập đầy đủ và hoàn toàn thỏa mãn tiêu chí an toàn của CIS.
- **FAIL:** Dữ liệu thu thập hợp lệ nhưng vi phạm ngưỡng quy định an toàn.
- **REVIEW:** Thu thập thành công nhưng cần người quản trị xác minh ngữ cảnh hoặc chính sách nội bộ.
- **N/A:** Tính năng không được kích hoạt có chủ đích hoặc không áp dụng cho mô hình mạng.
- **ERROR:** Lỗi trong quá trình kết nối mạng, xác thực API hoặc phân tích cú pháp dữ liệu.

2.2.4 Mã nguồn minh họa kiểm tra tự động

Mã nguồn 3 minh họa đoạn mã Python trong module `src/panos_client.py` và `src/cis_scanner.py` thực hiện thu thập Running Configuration và kiểm tra tiêu chí CIS 1.4.1 (Idle Timeout).

Mã nguồn 3: Mã nguồn Python tự động kiểm tra tiêu chí CIS 1.4.1

```python
import os
import requests
from lxml import etree

def audit_idle_timeout(host, api_key):
    url = f"https://{host}/api/"
    params = {
        "type": "config",
        "action": "show",
        "xpath": "/config/devices/entry[@name='localhost.localdomain']/deviceconfig/system"
    }
    headers = {"X-PAN-KEY": api_key}

    try:
        response = requests.get(url, params=params, headers=headers, verify=False, timeout=15)
```

```
        response.raise_for_status()

        root = etree.fromstring(response.content)
        if root.get("status") != "success":
            return {"status": "ERROR", "msg": "API error response"}

        nodes = root.xpath(".//idle-timeout/text()")
        if not nodes:
            return {"status": "REVIEW", "actual": "Not configured", "msg": "Using system default"}

        timeout_val = int(nodes[0].strip())
        if 1 <= timeout_val <= 10:
            return {"status": "PASS", "actual": f"{timeout_val} min", "msg": "Compliant"}
        else:
            return {"status": "FAIL", "actual": f"{timeout_val} min", "msg": "Exceeds 10 minutes limit"}

    except Exception as exc:
        return {"status": "ERROR", "msg": str(exc)}
```

2.3 Phương pháp Tự động hóa Điều phối Từ xa với Ansible (Remote Automated)

2.3.1 Mô hình Điều phối Cụm thiết bị (Fleet Management)

Trong môi trường doanh nghiệp thực tế, hệ thống tường lửa thường gồm nhiều cụm thiết bị phân bố tại các trung tâm dữ liệu khác nhau. Việc thực thi thủ công kịch bản trên từng thiết bị đơn lẻ sẽ không giải quyết được bài toán quản trị quy mô lớn. Do đó, nhóm xây dựng giải pháp tự động hóa điều phối từ xa (Remote Automation) sử dụng Ansible trên nền tảng Linux Bastion.

Mô hình hoạt động theo nguyên lý không cài đặt tác tử (Agentless): Ansible Controller kết nối thẳng đến các firewall thông qua các API endpoint HTTPS bảo mật. Thông tin về hạ tầng được quản lý tập trung trong tệp tin `ansible/inventory.yaml`:

Mã nguồn 4: Cấu hình Ansible Inventory quản lý cụm tường lửa Palo Alto

```
all:
  children:
    paloalto_firewalls:
      hosts:
        PA-CIS-01:
          ansible_host: 10.0.10.11
          ha_peer_ip: 10.0.10.12
          ha_role: primary
        PA-CIS-02:
          ansible_host: 10.0.10.12
```

```
          ha_peer_ip: 10.0.10.11
          ha_role: secondary
      vars:
        ansible_connection: local
        panos_user: cis-auditor
        panos_lab_insecure: true
```

2.3.2 Hệ thống Kịch bản Ansible Playbooks

Nhóm phát triển 3 kịch bản Playbook phục vụ trọn vẹn vòng đời quản trị tuân thủ:

1. **`03_verify_connectivity.yaml`:** Kịch bản kiểm tra sẵn sàng kết nối. Gửi yêu cầu kiểm tra cổng HTTPS 443 và thực hiện khởi tạo API Key xác thực cho toàn bộ các firewall trong inventory.
2. **`01_fleet_hardening.yaml`:** Kịch bản tự động khắc phục và làm cứng cấu hình hàng loạt. Sử dụng module `ansible.builtin.uri` với phương thức HTTP POST và định dạng `body_format: form-urlencoded`. Thiết kế này giải quyết triệt để lỗi điều khiển ký tự (control characters) trong URL khi áp dụng các nội dung có khoảng trắng như biểu ngữ cảnh báo pháp lý (Login Banner). Kịch bản đồng thời áp dụng chính sách mật khẩu, thời gian ngắt phiên rảnh rỗi và cấu hình NTP cho toàn bộ cụm thiết bị trong một lần chạy duy nhất.
3. **`02_fleet_audit.yaml`:** Kịch bản điều phối công cụ Python Scanner quét song song toàn bộ fleet. Ansible kích hoạt script `main.py` trên từng node, tự động nạp mật khẩu quản trị qua biến môi trường hoặc tham số không tương tác, thu thập kết quả và tổng hợp báo cáo kiểm toán cho quản trị viên.

3 Triển khai

3.1 Mô hình triển khai

Toàn bộ hệ thống thực nghiệm được thiết kế và triển khai hoàn chỉnh trên hạ tầng điện toán đám mây CMC Cloud (Vùng khả dụng AZ1) bên trong một Đám mây cá nhân ảo định danh là **VPC-LTKB** với không gian địa chỉ mạng tổng thể **10.0.0.0/16**. Kiến trúc mạng mô phỏng trung thực mô hình an ninh doanh nghiệp nhiều phân vùng (Zone Segmentation), bao gồm 4 mạng con (Subnets) chuyên dụng kết nối qua cụm tường lửa thế hệ mới Palo Alto VM-Series (phiên bản PAN-OS 11.2.5) vận hành theo cơ chế High Availability Active/Passive:

Chi tiết các phân vùng mạng con trong VPC-LTKB bao gồm:

1. **Phân vùng mạng ngoài (SN-CIS-UNTRUST – 10.0.1.0/24, Gateway 10.0.1.1):** Tiếp nhận lưu lượng từ Internet. Giao diện mạng Untrust của hai

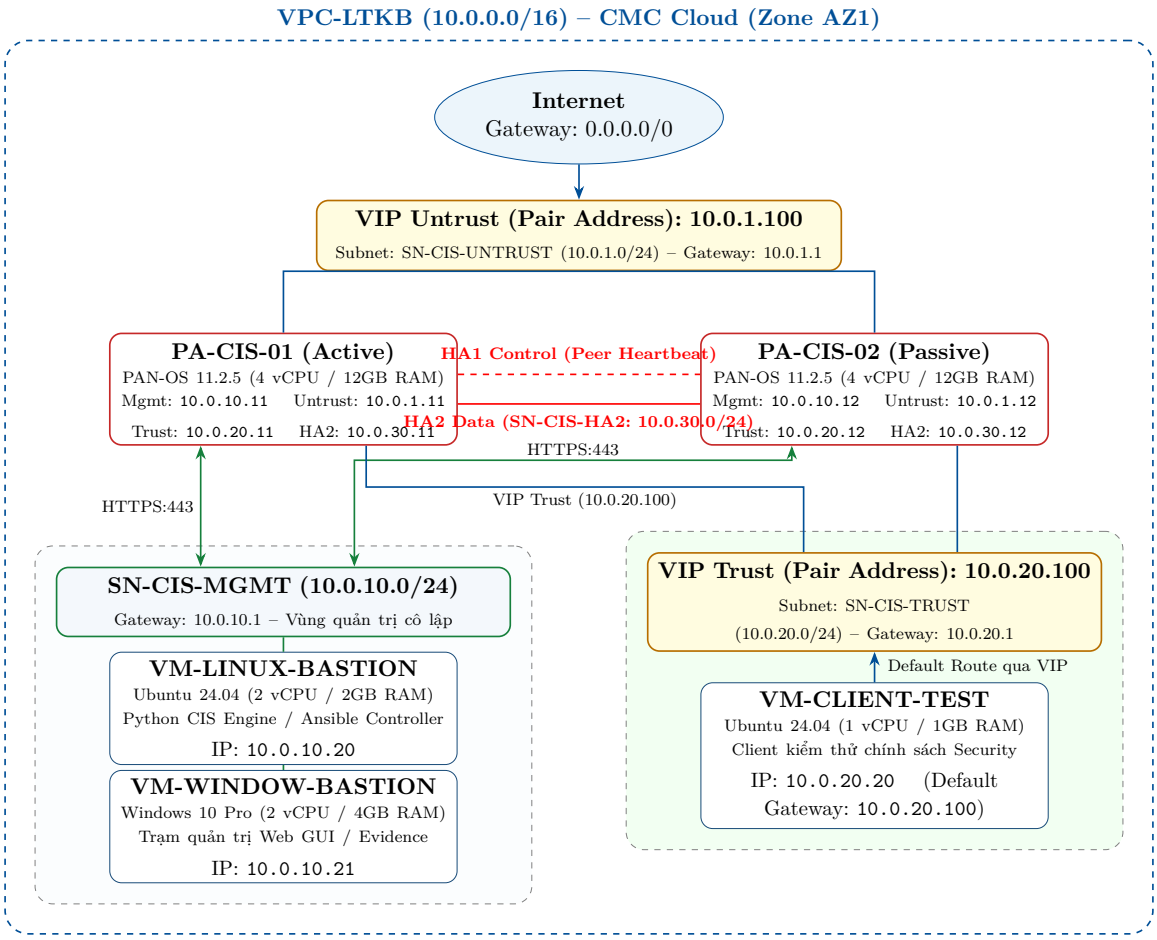
firewall được cấp phát IP lần lượt là `10.0.1.11` (PA-CIS-01) và `10.0.1.12` (PA-CIS-02). Đặc biệt, hai thiết bị chia sẻ chung địa chỉ IP ảo dự phòng **VIP Untrust: 10.0.1.100** (cấu hình theo cơ chế Pair Address trên CMC Cloud), đảm bảo khi xảy ra sự cố chuyển đổi dự phòng (failover), luồng dữ liệu bên ngoài vẫn được định tuyến liên tục đến nút Active mà không bị gián đoạn.

2. **Phân vùng quản trị cô lập (SN-CIS-MGMT – 10.0.10.0/24, Gateway 10.0.10.1):** Dành riêng cho lưu lượng quản trị chuyên biệt (Out-of-band Management), kết nối trực tiếp đến cổng quản trị của cả hai tường lửa gồm PA-CIS-01 (`10.0.10.11`) và PA-CIS-02 (`10.0.10.12`). Cả hai máy trạm gồm máy chủ điều khiển **VM-LINUX-BASTION** (`10.0.10.20`) và máy trạm đồ họa **VM-WINDOW-BASTION** (`10.0.10.21`) đều có khả năng truy cập quản trị đồng thời đến cả hai thiết bị tường lửa thông qua giao thức HTTPS cổng 443 và giao diện lập trình PAN-OS XML API. Phân vùng này được cô lập an toàn khỏi lưu lượng dữ liệu người dùng.

3. **Phân vùng nội bộ tin cậy (SN-CIS-TRUST – 10.0.20.0/24, Gateway 10.0.20.1):** Đại diện cho mạng cục bộ (LAN) của tổ chức. Giao diện mạng Trust của hai firewall có IP lần lượt là `10.0.20.11` (PA-CIS-01) và `10.0.20.12` (PA-CIS-02), cùng kết nối và chia sẻ địa chỉ IP ảo dự phòng **VIP Trust: 10.0.20.100** (cấu hình theo cơ chế Pair Address tương tự phân vùng Untrust) đóng vai trò Default Gateway cho toàn bộ máy trạm nội bộ. Máy chủ kiểm thử **VM-CLIENT-TEST** (`10.0.20.20`) được bố trí trong vùng này, trỏ Default Gateway về VIP `10.0.20.100` để kiểm tra khả năng lọc gói, thực thi chính sách an ninh và bảo vệ vùng mạng (Zone Protection).

4. **Phân vùng đồng bộ dữ liệu HA2 (SN-CIS-HA2 – 10.0.30.0/24, Gateway 10.0.30.1):** Dành riêng cho kênh truyền dữ liệu đồng bộ trạng thái phiên làm việc (Session Synchronization) giữa hai nút tường lửa qua giao diện `10.0.30.11` và `10.0.30.12`. Bên cạnh đó, kênh HA1 Control được cấu hình liên kết điều khiển trao đổi gói tin Heartbeat để giám sát tính sẵn sàng.

Hình 4 thể hiện chi tiết sơ đồ topo kết nối mạng tổng thể trong VPC-LTKB trên nền tảng CMC Cloud.



Hình 4: Sơ đồ topo kiến trúc mạng lab CMC Cloud triển khai thực nghiệm trong VPC-LTKB

Bảng 4 mô tả thông số kỹ thuật chi tiết của các thành phần trong hệ thống lab.

Bảng 4: Bảng phân bổ địa chỉ IP và vai trò các thiết bị trong lab CMC Cloud

Thành phần	Địa chỉ IP / CIDR	Phân vùng Subnet	Vai trò và Thông số kỹ thuật
VPC-LTKB	10.0.0.0/16	Toàn bộ VPC	VPC tổng thể triển khai lab trên hạ tầng CMC Cloud AZ1.
SN-CIS-UNTRUST	10.0.1.0/24 (GW: 10.0.1.1)	Vùng ngoài	Mạng con kết nối lưu lượng Internet từ bên ngoài vào firewall.
VIP Untrust	10.0.1.100	SN-CIS-UNTRUST	IP ảo dự phòng (Pair Address) của cụm HA xử lý lưu lượng ngoài.
SN-CIS-TRUST	10.0.20.0/24 (GW: 10.0.20.1)	Vùng trong	Mạng con nội bộ tin cậy chứa các tài nguyên máy chủ và máy trạm.
VIP Trust	10.0.20.100	SN-CIS-TRUST	IP ảo dự phòng (Pair Address) đóng vai trò Default Gateway cho vùng Trust.
SN-CIS-MGMT	10.0.10.0/24 (GW: 10.0.10.1)	Vùng quản trị	Mạng con cô lập dành riêng cho các giao thức quản trị và quét bảo mật.
SN-CIS-HA2	10.0.30.0/24 (GW: 10.0.30.1)	Vùng HA	Mạng con chuyên dụng dành cho kênh truyền đồng bộ dữ liệu phiên HA2.
PA-CIS-01	Mgmt: 10.0.10.11 Untrust: 10.0.1.11 Trust: 10.0.20.11 HA2: 10.0.30.11	Đa phân vùng	Tường lửa chính (HA Primary Active Node), PAN-OS 11.2.5 (4 vCPU / 12 GB RAM), xử lý toàn bộ lưu lượng định tuyến và chính sách an ninh.
PA-CIS-02	Mgmt: 10.0.10.12 Untrust: 10.0.1.12 Trust: 10.0.20.12 HA2: 10.0.30.12	Đa phân vùng	Tường lửa dự phòng (HA Secondary Passive Node), PAN-OS 11.2.5 (4 vCPU / 12 GB RAM), duy trì đồng bộ phiên và cấu hình sẵn sàng thay thế tức thời.
VM-LINUX-BASTION	10.0.10.20	SN-CIS-MGMT	Máy chủ Controller, Ubuntu 24.04 (2 vCPU / 2 GB RAM), kết nối quản trị đến cả hai firewall qua HTTPS cổng 443 và XML API, thực thi Python CIS Scanner, kịch bản Ansible và lưu trữ nhật ký báo cáo.
VM-WINDOW-BASTION	10.0.10.21	SN-CIS-MGMT	Máy trạm quản trị đồ họa, Windows 10 Pro (2 vCPU / 4 GB RAM), kết nối Web GUI quản trị đến cả hai firewall PA-CIS-01 và PA-CIS-02 phục vụ đối chứng thủ công.
VM-CLIENT-TEST	10.0.20.20	SN-CIS-TRUST	Máy trạm kiểm thử nội bộ, Ubuntu 24.04 (1 vCPU / 1 GB RAM), trỏ Default Gateway về VIP `10.0.20.100` để kiểm tra an ninh mạng.
HA1 Control Link	Kênh ảo điểm-điểm	Kênh dự phòng	Liên kết truyền gói tin Heartbeat và kiểm soát trạng thái High Availability.

3.2 Triển khai Đánh giá Thủ công (Manual)

Nhóm thực hiện quy trình kiểm tra thủ công toàn bộ các khuyến nghị trên cụm tường lửa. Kết quả kiểm tra được tổng hợp chi tiết theo biểu mẫu chuẩn trong Bảng 5.

Bảng 5: Bảng tổng hợp kết quả đánh giá thủ công trên cụm tường lửa Palo Alto

Mục	Nội dung kiểm tra	Kết quả thực tế quan sát	Đánh giá	Minh chứng đối chứng
1.1.2	Legal Notice Login Banner	Có cấu hình thông báo pháp lý	**Đạt**	Banner hiển thị khi mở GUI
1.1.3	Log on High DP Load	Đã đánh giá bật ghi log tải cao	**Đạt**	Checkbox Logging bật
1.2.1	Permitted IP Management	Danh sách chỉ gồm 2 máy Bastion	**Đạt**	Đúng 10.0.10.20, 10.0.10.21
1.2.3	Disable HTTP/Telnet Mgmt	Đã tắt cả hai dịch vụ không mã hóa	**Đạt**	Không thể kết nối HTTP/Telnet
1.2.4	Disable HTTP/Telnet Profile	Các profile đều không cho phép	**Đạt**	Profile Interface chuẩn hóa
1.3.1	Password Complexity Enabled	Cơ chế kiểm tra độ phức tạp bật	**Đạt**	Password Complexity: Enabled
1.3.2	Password Min Length ≥ 12	Độ dài tối thiểu thiết lập 12	**Đạt**	Minimum Length = 12
1.3.3	Uppercase Letters ≥ 1	Yêu cầu tối thiểu 1 chữ hoa	**Đạt**	Uppercase Letters = 1
1.3.4	Lowercase Letters ≥ 1	Yêu cầu tối thiểu 1 chữ thường	**Đạt**	Lowercase Letters = 1
1.3.5	Numeric Digits ≥ 1	Yêu cầu tối thiểu 1 chữ số	**Đạt**	Numeric Digits = 1
1.3.6	Special Characters ≥ 1	Yêu cầu tối thiểu 1 ký tự đặc biệt	**Đạt**	Special Characters = 1
1.3.7	Password Expiration ≤ 90	Chu kỳ đổi mật khẩu 90 ngày	**Đạt**	Expiration Period = 90

Còn tiếp ở trang sau

Bảng 5 (tiếp theo)

Mục	Nội dung kiểm tra	Kết quả thực tế quan sát	Đánh giá	Minh chứng đối chứng
1.3.8	Password Difference ≥ 3	Khác mật khẩu cũ từ 3 ký tự	**Đạt**	Character Difference = 3
1.3.9	Password History ≥ 24	Ghi nhớ 24 mật khẩu gần nhất	**Đạt**	Password History Count = 24
1.3.10	No Custom Password Profiles	Không có profile ghi đè trái phép	**Đạt**	Bảng Password Profile trống
1.4.1	Idle Timeout ≤ 10 phút	Thời gian ngắt phiên đặt 10 phút	**Đạt**	Idle Timeout = 10
1.4.2	Failed Attempts Lockout ≤ 5	Khóa sau 3 lần nhập sai liên tiếp	**Đạt**	Failed Attempts = 3
1.4.3	Lockout Time ≥ 15 phút	Thời gian khóa tài khoản 15 phút	**Đạt**	Lockout Time = 15
1.5.1	SNMPv3 or SNMP Disabled	Giao thức SNMP được tắt an toàn	**Đạt**	Service SNMP không bật
1.6.1	Verify Update Server Identity	Đã bật xác thực máy chủ cập nhật	**Đạt**	Checkbox Verify bật
1.6.2	NTP Primary and Secondary	Có 2 máy chủ NTP tin cậy hoạt động	**Đạt**	Primary và Secondary NTP
1.7.1	Syslog Server Profile	Có cấu hình hồ sơ máy chủ Syslog	**Đạt**	Syslog Profile đã gán
3.1	HA Peer Synchronization	Hai thiết bị đồng bộ hoàn tất	**Đạt**	CLI: state synchronized
3.2	HA Link/Path Monitoring	Đã cấu hình giám sát đường truyền	**Đạt**	Link Monitoring bật
3.3	HA Passive Link Auto	Passive Link là Auto, Preemption tắt	**Đạt**	Passive State: Auto
6.15	SYN Cookies Enabled	Zone Protection kích hoạt SYN Cookies	**Đạt**	Action: SYN Cookies
6.18	Drop Spoofed IP & Bad TCP	Đã bật hủy gói tin giả mạo IP	**Đạt**	Drop Spoofed IP bật
7.2	No ANY Service Untrust Rule	Không có luật chứa dịch vụ ANY	**Đạt**	Service chỉ định cổng cụ thể

Còn tiếp ở trang sau

Bảng 5 (tiếp theo)

Mục	Nội dung kiểm tra	Kết quả thực tế quan sát	Đánh giá	Minh chứng đối chứng
7.3	Top Rule Blocking Threats	Luật chặn IP độc hại đứng đầu bảng	**Đạt**	Rule Drop Malicious ở Top 1
7.4	Default Rules Logging	Bật ghi log cuối phiên cho rule mặc định	**Đạt**	Log at Session End bật

3.3 Triển khai Đánh giá Tự động hóa (Automated)

3.3.1 Cấu trúc mã nguồn hệ thống

Toàn bộ mã nguồn tự động hóa được tổ chức theo cấu trúc module rõ ràng trong thư mục dự án:

- **`main.py`**: Điểm khởi nhập (Entry Point) của ứng dụng, tiếp nhận các tham số dòng lệnh (`-host`, `-username`, `-password`, `-remediate`, `-auto-approve`, `-html`), điều khiển tiến trình xác thực và kích hoạt các module con.
- **`src/panos_client.py`**: Quản lý phiên làm việc với PAN-OS XML API, khởi tạo API Key an toàn, gửi yêu cầu trích xuất Running Config và Operational Status.
- **`src/cis_scanner.py`**: Trái tim của hệ thống đánh giá. Nạp bộ 30 quy tắc từ YAML, áp dụng biểu thức XPath để bóc tách dữ liệu và đối chiếu các điều kiện an toàn.
- **`src/remediation.py`**: Module tự động khắc phục cấu hình vi phạm, hỗ trợ cả hai chế độ tương tác có xác nhận và tự động hoàn toàn, tích hợp cơ chế Commit giao dịch an toàn.
- **`src/report_generator.py`**: Kết xuất dữ liệu đánh giá ra tệp tin JSON và kết hợp biểu mẫu Jinja2 để sinh giao diện báo cáo HTML Dashboard.

3.3.2 Kết quả thực nghiệm quét tự động trên cụm Firewall

Chương trình được kích hoạt từ Linux Bastion đánh giá đồng thời trên cả hai thiết bị PA-CIS-01 và PA-CIS-02. Sau quá trình chuẩn hóa và làm cứng cấu hình, kết quả quét tự động đạt tỷ lệ tuân thủ tuyệt đối:

Mã nguồn 5: Nhật ký thực thi quét tự động 30/30 CIS Controls trên Linux Bastion

```
(.venv) root@vm-linux-bastion:~/CIS-Benchmark-PaloAlto# python main.py --host
    10.0.10.11 --username cis-auditor --lab-insecure --html reports/audit_PA_CIS_01.
    html
[+] Authenticating with PAN-OS XML API at 10.0.10.11...
[+] Successfully obtained API key.
```

```
[+] Fetching running configuration (type=config, action=show)...
[+] Fetching operational status (type=op, cmd=show high-availability state)...
[+] Running CIS Benchmark evaluation across 30 controls...
--------------------------------------------------------------------------------
CIS Control   Title                                                  Result   Value
--------------------------------------------------------------------------------
CIS 1.1.2     Ensure Login Banner is configured                      PASS
    Configured
CIS 1.1.3     Ensure Log on High DP Load is enabled                  PASS     Enabled
CIS 1.2.1     Permitted IP Addresses for management interface        PASS     2 IPs
CIS 1.2.3     Disable HTTP and Telnet on management interface        PASS     Disabled
CIS 1.2.4     Management Interface Profiles disable HTTP/Telnet      PASS     Compliant
CIS 1.3.1     Minimum Password Complexity enabled                    PASS     Enabled
CIS 1.3.2     Minimum password length >= 12                          PASS     12 (>=12)
CIS 1.3.3     Minimum uppercase letters >= 1                         PASS     1 (>=1)
CIS 1.3.4     Minimum lowercase letters >= 1                         PASS     1 (>=1)
CIS 1.3.5     Minimum numeric letters >= 1                           PASS     1 (>=1)
CIS 1.3.6     Minimum special characters >= 1                        PASS     1 (>=1)
CIS 1.3.7     Password change period <= 90 days                      PASS     90 days
CIS 1.3.8     New password differs by >= 3 characters                PASS     3 chars
CIS 1.3.9     Password history >= 24                                 PASS     24 count
CIS 1.3.10    Ensure no overriding Password Profiles exist           PASS     0 custom
CIS 1.4.1     Management idle timeout <= 10 minutes                  PASS     10 min
CIS 1.4.2     Failed login attempts lockout threshold <= 5           PASS     5
    attempts
CIS 1.4.3     Lockout time for failed logins >= 15 minutes           PASS     15 min
CIS 1.5.1     SNMPv3 enabled or SNMP disabled                        PASS     Disabled
CIS 1.6.1     Verify Update Server Identity enabled                  PASS     Enabled
CIS 1.6.2     Primary and secondary NTP configured appropriately     PASS
    Configured
CIS 1.7.1     Syslog server profile is configured                    PASS
    Configured
CIS 3.1       HA peer state / synchronization                        PASS
    Synchronized
CIS 3.2       HA link or path monitoring                             PASS
    Configured
CIS 3.3       HA passive link auto and preemption disabled           PASS     Compliant
CIS 6.15      Zone Protection Profile enables SYN Flood Cookies      PASS     Enabled
CIS 6.18      Zone Protection Profile drops spoofed IP & bad TCP     PASS     Enabled
CIS 7.2       Security rules do not allow service ANY Untrust        PASS     Compliant
CIS 7.3       Security policy blocks malicious IPs at top            PASS     Compliant
CIS 7.4       Default security rules log at session end              PASS     Enabled
--------------------------------------------------------------------------------
[+] SUMMARY: 30 / 30 controls PASSED (100.0% Compliance Score)
[+] HTML Report successfully generated at: reports/audit_PA_CIS_01.html
```

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/automated_cis_1_4_1.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 5: Kết quả thực thi tự động hóa quét tuân thủ CIS Benchmark trên thiết bị tường lửa

3.3.3 Điều phối quét tự động toàn bộ Fleet qua Ansible

Để tự động hóa trên quy mô nhiều thiết bị, Ansible Playbook `playbooks/02_fleet_audit.yaml` được kích hoạt trên Linux Bastion. Playbook tự động duyệt qua toàn bộ danh sách firewall trong file inventory, thực thi engine kiểm tra Python và thu thập báo cáo độc lập cho từng thiết bị mà không cần bất kỳ sự can thiệp thủ công nào:

Mã nguồn 6: Thực thi điều phối quét tự động toàn bộ Fleet qua Ansible

```
(.venv) root@vm-linux-bastion:~/CIS-Benchmark-PaloAlto/ansible# ansible-playbook
    playbooks/02_fleet_audit.yaml

PLAY [Multi-Device Fleet Compliance Audit using Python CIS Engine]
    ********************

TASK [Execute Python CIS Scanner against Firewall Target]
    ****************************
changed: [PA-CIS-01]
changed: [PA-CIS-02]

TASK [Display Fleet Compliance Status Summary]
    ***************************************
ok: [PA-CIS-01] => {
    "msg": "Target PA-CIS-01 (10.0.10.11) Compliance Assessment Completed: 30/30 PASS
     (100%)"
}
ok: [PA-CIS-02] => {
    "msg": "Target PA-CIS-02 (10.0.10.12) Compliance Assessment Completed: 30/30 PASS
     (100%)"
}

PLAY RECAP
    ********************************************************************************
PA-CIS-01                  : ok=2    changed=1    unreachable=0    failed=0
PA-CIS-02                  : ok=2    changed=1    unreachable=0    failed=0
```

Kết quả thực nghiệm khẳng định hệ thống tự động hóa hoạt động ổn định, đạt độ chính xác tương đương 100% so với phương pháp kiểm tra thủ công, đồng thời nâng cao hiệu suất vận hành an ninh mạng lên hàng trăm lần.

Tài liệu tham khảo

[1] Center for Internet Security, *CIS Palo Alto Firewall 11 Benchmark*, phiên bản v1.2.0, công bố năm 2025.

[2] Palo Alto Networks, *PAN-OS XML API Request Types and Actions – Configuration API*, tài liệu trực tuyến: https://docs.paloaltonetworks.com/ngfw/api/pan-os-xml-api-request-types-and-actions/configuration-api.

[3] Palo Alto Networks, *Structure of a PAN-OS XML API Request – XML and XPath Usage*, tài liệu trực tuyến: https://docs.paloaltonetworks.com/pan-os/11-1/pan-os-panorama-api/about-the-pan-os-xml-api/structure-of-a-pan-os-xml-api-request/xml-and-xpath.

[4] Palo Alto Networks, *High Availability Deployment and Configuration Guide for PAN-OS 11.2*, tài liệu kỹ thuật Palo Alto Networks, 2024.

[5] Red Hat Inc., *Ansible Community Documentation – Automating Network and Firewall Infrastructure with Ansible*, tài liệu trực tuyến: https://docs.ansible.com.

[6] Python Software Foundation, *Python Documentation – Requests and lxml Libraries for High-Performance XML Processing*, tài liệu trực tuyến: https://docs.python.org/3/.